

3.1.9 Lesson Review

Date: 3/9/2026, 10:14:21 PM

Time Spent: 13:17

Score: 100%

Passing Score: 80%



Which of the following is a recommended security control for authenticating devices and users accessing AI system APIs?

- ☐ Allowing limited API access based on IP address whitelisting, but not requiring additional user authentication mechanisms.
- ☒ Implementing multi-factor authentication methods such as certificates or one-time tokens, while also requiring strong user and device identity verification for API access. ✓ Correct
- ☐ Relying on secure VPN tunnels for API communication, but foregoing application-layer authentication and input validation controls.
- ☐ Implementing basic username and password authentication, while encrypting the credentials in transit, but not enforcing password complexity requirements.

Explanation

Implementing multi-factor authentication (MFA) with certificates or one-time tokens, plus strong user and device identity verification for API access, is correct. MFA requires multiple proofs of identity, ensuring that only trusted users and devices interact with the API. This layered security prevents unauthorized API access, even if one factor is compromised, and aligns with security best practices.

Allowing API access based solely on IP whitelisting is incorrect. While it limits access by network, anyone on an approved IP can potentially exploit the API without further identity checks. MFA is essential for verifying the actual user or device.

Relying on basic username and password authentication without enforcing complexity or MFA is incorrect. Weak or reused passwords are easily exploited.

Relying only on VPNs is incorrect. VPNs protect the network, but robust API authentication and input validation remain essential.

Related Content

 3.1.2 AI Access Control Models

 3.1.8 Network and API Access

resources\questions\q_network_and_api_accerss_01._question.question.xml

Question 2

✓ Correct

In access control systems for AI, what is assigned to subjects in order to manage how they interact with resources?

- ☐ Logging configurations
- ☐ Physical tokens
- ☐ Data sets
- ☒ Subject rights ✓ Correct

Explanation

Subject rights is the correct answer. Access control principles involve assigning rights or permissions to subjects (such as users, devices, or processes) to determine and control their interactions with various resources.

Data sets is incorrect. Data sets are objects or resources that the subjects may access, not what is assigned to the subjects themselves.

Logging confirmations is incorrect. Logging configurations define how activities are recorded for monitoring or auditing but are not the means by which access is determined or assigned to a subject.

Physical tokens is incorrect. Physical tokens can be used as authentication factors but do not define or control how a subject interacts with resources in terms of permissions; these are mechanisms for proving identity, not rights assignment.

Related Content

 3.1.1 Access Control Principles for AI

 3.1.5 Model Access

resources\questions\q_access_control_principles_for_ai_03.question.xml

Given an AI system that handles both public and sensitive personal data while connecting to external cloud services via APIs, which of the following approaches BEST demonstrates an effective evaluation of security controls for network and API access?

- ☒ Reviewing the effectiveness of firewalls, multi-factor authentication, and enforcing role-based access, then recommending adjustments based on current compliance requirements and threat assessments. ✓ Correct
- ☐ Applying the same access controls to all APIs regardless of the type of data they handle or the level of sensitivity involved, to maintain consistency and reduce administrative overhead.
- ☐ Focusing solely on API throttling policies to prevent denial of service attacks, assuming this effectively mitigates all types of network threats.
- ☐ Limiting the use of HTTPS protocols to internal communication and relying on standard HTTP for external network communication for ease of troubleshooting, while ensuring user credentials are checked during login.

Explanation

Reviewing firewalls, multi-factor authentication, and role-based access controls, then recommending adjustments based on compliance and threat assessments, is correct. This approach evaluates and enhances both technical and procedural security controls, ensuring strategies are current and comprehensive.

Focusing only on API throttling for DoS attacks is incorrect. While helpful, throttling does not address authentication, encryption, or other threats. Effective evaluations must cover a range of controls.

Applying the same access controls to all APIs is incorrect. Uniform controls overlook data sensitivity and risk; security should be tailored based on context and least privilege.

Limiting HTTPS to internal communication and using HTTP externally is incorrect. This exposes data to interception. HTTPS and secure authentication are necessary for all communications, including external networks.

Related Content

 3.1.2 AI Access Control Models

 3.1.8 Network and API Access

resources\questions\q_network_and_api_accerss_02._question.question.xml

Maria is an AI engineer in her organization. She has been asked to configure access controls for a new machine learning model that handles sensitive customer information.

The organization wants to ensure that only authorized personnel can update or retrain the model, while data analysts should only be able to use the model to generate predictions.

How should Maria configure model access according to best practices?

- ☐ Configure all model access through a single shared admin account to simplify permission management and reduce overhead.
- ☐ Grant data analysts "training and modification" permissions and restrict AI engineers to "prediction/inference" operations to separate roles and avoid errors.
- ☒ Assign "training and modification" permissions exclusively to AI engineers like Maria, while granting "prediction/inference" permissions to data analysts. Log and review all model interactions regularly. ✓ Correct
- ☐ Allow all team members, including data analysts and external contractors, full access to both modify and use the model to encourage faster iterative development and problem solving.

Explanation

Assigning "training and modification" permissions to AI engineers and "prediction/inference" to data analysts, with regular logging, is correct. This enforces least privilege, ensuring users have only necessary access. Engineers maintain the model, while analysts use it for inference. Logging supports auditing and catches unauthorized activity.

Allowing all team members, including contractors, full access is incorrect. This ignores security best practices and exposes sensitive data and the model to risks like unauthorized changes or leaks. Only qualified personnel should have modification privileges.

Using a single shared admin account is incorrect, as it removes accountability and increases risk. Individual accounts and granular permissions are necessary for security.

Letting data analysts modify or train the model is incorrect. Only engineers should have such access, maintaining model integrity and security.

Related Content

 3.1.1 Access Control Principles for AI

 3.1.5 Model Access

resources\questions\q_model_access_02.question.xml

Question 5

✓ Correct

What is the primary purpose of the identification process in Identity and Access Management (IAM) for AI systems?

- ☐ To track and log user activity for later review and auditing.
- ☐ To prove the credentials of a user before accessing a resource.
- ☐ To determine what actions a user is allowed to perform on specific resources.

- ☒ To create an account or identity that uniquely represents the user, device, or process. ✓ Correct

Explanation

To create an account or identity that uniquely represents the user, device, or process is the correct answer. Identification is the process of establishing a unique identity for each user, device, or process.

To determine what actions a user is allowed to perform on specific resources is incorrect. This describes authorization, which decides user permissions for resources.

To prove the credentials of a user before accessing a resource is incorrect. This is the role of authentication, which involves validating a subject's credentials.

To track and log user activity for later review and auditing is incorrect. This describes accounting, not identification. Accounting involves logging and monitoring access.

Related Content

 3.1.1 Access Control Principles for AI

 3.1.5 Model Access

resources\questions\q_access_control_principles_for_ai_02.question.xml

An enterprise organization is deploying a machine learning service in a multi-cloud environment. The security team wants to guarantee consistent, auditable enforcement of access controls across development, testing, and production environments.

They decide to implement "policy as code" to manage who can access data sets, retrain models, and use APIs. However, shortly after deployment, they notice that changes to access policy are taking longer to propagate to all environments, and some permissions are not updated as intended.

What is the BEST way for the security team to address this and ensure their policy as code solution works?

- ☒ Automate the testing and deployment of policy as code so that any policy updates are validated, version-controlled, and rolled out to all target environments simultaneously. ✓ Correct
- ☐ Temporarily disable policy as code, revert to manual access control updates, and document every change in spreadsheets to avoid confusion during the transition.
- ☐ Assign a dedicated administrator to manually apply access changes in each environment after reviewing the policy scripts, to ensure no errors occur during the update process.
- ☐ Restrict all policy updates to only production environment first; after several weeks, apply successful changes to development and testing environments.

Explanation

Automating the testing and deployment of policy as code so updates are validated, versioned, and rolled out to all environments simultaneously is correct. This leverages automation, version control, and consistency, ensuring policies are accurate, auditable, and compliant across all environments.

Assigning an administrator to manually apply changes is incorrect. Manual updates defeat policy as code's purpose, are inefficient, error-prone, hard to audit, and do not scale or ensure consistency.

Restricting updates to production first, then applying them elsewhere, is incorrect. This causes environment misalignment, risks untested changes in production, and undermines the synchronization purpose of policy as code.

Disabling policy as code and reverting to manual updates documented in spreadsheets is incorrect. This increases errors, loses audit trails, reduces agility, and weakens security and compliance.

Related Content

 3.1.2 AI Access Control Models

 3.1.8 Network and API Access

resources\questions\q_ai_access_control_models_04.question.xml

A financial services company is building an AI-powered chatbot to assist customers with account inquiries. This chatbot accesses various data types, including public interest rates, customer transaction histories, and social security numbers.

As the systems administrator, you must implement controls that address special handling requirements for sensitive data within the AI system, ensuring compliance with all applicable regulations.

Which of the following approaches BEST addresses the special handling of sensitive data such as personally identifiable information (PII) and ensures regulatory compliance within the AI system?

- ☐ Configure the chatbot to access customer data through an encrypted API endpoint, with all access attempts monitored and alerts generated for suspicious activities. Customers are shown clear data handling notices before interacting with the chatbot.
- ☐ Encrypt only the database files that store sensitive data, restrict network access to a single firewall, and implement an internal policy stating that employees must not misuse sensitive information, without configuring access controls at the application or agent level.
- ☒ Anonymize sensitive PII within the dataset before use, enforce access restrictions for agents interacting with this data, and schedule regular audits to verify compliance with data protection regulations like GDPR and HIPAA. ✔ Correct
- ☐ Allow agents to access sensitive data only after successful multifactor authentication, maintain a detailed activity log for each access session, and require all agents to complete certified privacy training annually.

Explanation

Anonymizing sensitive PII in the dataset, enforcing access restrictions for agents, and scheduling regular audits for GDPR/HIPAA compliance is correct. These measures protect privacy, ensure only authorized agents interact with data, and maintain ongoing compliance, matching best practices.

Allowing access only after multifactor authentication, maintaining detailed logs, and requiring annual privacy training is incorrect. While helpful, these steps lack the crucial enforcement of least privilege and role-based access controls. Technical restrictions are essential for compliance beyond just authentication and monitoring.

Encrypting only the database, restricting network access to one firewall, and relying on internal misuse policies is incorrect. These steps lack application-level access controls. Encryption alone can't prevent inappropriate access after decryption, and policies must be technically enforced.

Allowing chatbot access solely via encrypted API with monitoring is incorrect. Without field-level controls, sensitive data could be overexposed, violating privacy requirements.

Related Content

 3.1.4 Threat Landscape of AI Systems

 3.1.7 Data and Agent Access

resources\questions\q_data_and_agent_access_04.question.xml

A financial services company has deployed an AI-powered analytics platform. To meet regulatory requirements and mitigate the risk of unauthorized access, the IT team enforces granular permissions for users interacting with the platform. Each user's permissions are assigned based on their job functions, with options to read data, export reports, retrain models, or modify access controls.

Recently, during an audit, it was discovered that several users with "analyst" roles can retrain the model and export datasets when they should only be able to generate and read reports. Conversely, some researchers cannot access model retraining features, even though it is critical to their job.

How should the IT team apply granular permissions to resolve these access issues and support both security and functionality?

- ☐ Consolidate all permissions under a single "power user" role and request all users to share this account for complex tasks to avoid configuration complexity.
- ☐ Remove all permission restrictions except for senior management, allowing most users unrestricted platform access to encourage collaboration and innovation.
- ☐ Shift all user roles to the highest existing access level temporarily to avoid workflow interruptions, then slowly reduce permissions on a case-by-case basis as needed.
- ☒ Review and update user role definitions and associated permissions to ensure each user gets only the minimum necessary rights for their responsibilities, while enabling these functions for researchers. ✓ Correct

Explanation

Reviewing and updating user role definitions and permissions to ensure users get only the minimum rights needed for their jobs, while enabling key researcher functions, is correct. This enforces least privilege, tailors access to job roles, supports security and compliance, and resolves audit findings efficiently.

Shifting all users to the highest access level temporarily, then reducing access later, is incorrect. This exposes systems and data to security risks and noncompliance, even if only short-term, undermining the least privilege principle.

Consolidating permissions under a shared "power user" account is incorrect. Shared accounts remove accountability, prevent auditing, and create serious compliance and security risks.

Removing all restrictions except for senior management is incorrect. This invites data leaks, noncompliance, and regulatory violations, even if meant to encourage collaboration.

Related Content

 3.1.2 AI Access Control Models

 3.1.8 Network and API Access

resources\questions\q_ai_access_control_models_03.question.xml

Question 9

✓ Correct

Which of the following practices are recommended for securing privileged execution surfaces such as agents and tools, within an AI system? (Select three.)

- ☐ Ignoring regulatory requirements regarding data access.
- ☐ Permitting agents to access data without any anonymization.
- ☒ Setting time expirations for authentication secrets used by tools. ✓ Correct
- ☒ Maintaining detailed logging of all agent activity. ✓ Correct
- ☐ Disabling access controls for agents during routine operations to improve performance.
- ☐ Granting all agents administrative rights to all tools for flexibility.
- ☒ Allowing only pre-approved agents access to specific tools through allow lists. ✓ Correct

Explanation

Setting time expirations for authentication secrets used by tools is correct. Limiting secret duration helps prevent unauthorized or prolonged access if credentials are exposed.

Maintaining detailed logging of all agent activity is correct. Logging is vital for monitoring privileged actions, auditing, anomaly detection, and regulatory compliance.

Allowing access through pre-approved agent allow lists is correct. Allow lists restrict which agents can use specific tools, reducing risk and exposure.

Granting all agents administrative rights to all tools is incorrect. This violates the principle of least privilege and increases system risk.

Ignoring regulatory requirements is incorrect. Compliance with data access regulations is essential, especially for sensitive information.

Permitting data access without anonymization is incorrect. Anonymization protects privacy and is required for compliance.

Disabling access controls for performance is incorrect. Strong, consistent controls must always be enforced for security.

Related Content

resources\questions\q_data_and_agent_access_03.question.xml

Which of the following BEST describes a threat unique to AI systems that can directly manipulate the outputs by corrupting the training data?

- ☐ Distributed Denial of Service (DDoS)
- ☒ Data Poisoning ✓ Correct
- ☐ Hardware Failure
- ☐ User Authentication Failure

Explanation

Data poisoning is the correct answer. Data poisoning is a unique and significant threat for AI systems. It involves corrupting or manipulating the data used to train the AI model. When attackers introduce incorrect or biased data into the training set, they can influence the AI's outputs, causing it to make inaccurate or harmful decisions. This specifically targets the way AI models learn and generate outputs, making it a critical risk in AI environments.

Distributed Denial of Service (DDoS) is incorrect. While a DDoS attack (making the AI system unavailable by overwhelming it with traffic) is a general cybersecurity threat, it is not unique to AI systems and does not involve manipulating the outputs by corrupting the training data. It instead targets system availability rather than the accuracy or integrity of AI model outputs.

Hardware failure is incorrect. Hardware failure is a naturally occurring risk, such as a server malfunctioning due to component issues or environmental factors (e.g., power loss, overheating). While it can affect the AI system's availability, it is not an attack—nor is it related to corrupting the training data or manipulating output results.

User authentication failure is incorrect. User authentication failure occurs when the system cannot correctly verify a user's identity, risking unauthorized access. While this is a security concern, it does not describe a threat that manipulates AI outputs via the training data, as data poisoning does.

Related Content

 3.1.4 Threat Landscape of AI Systems

 3.1.7 Data and Agent Access

resources\questions\q_threat_landscape_of_ai_systems_01.question.xml

